



SEMANA 7 · CIFRADO EN TRÁNSITO: TLS/SSL, VPN/IPSEC

Por qué cifrar el tránsito

Parte 1 de 4 · Unidad 2

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

Cifrado en tránsito: por qué, y las garantías de TLS

Lo que ya protegimos y lo que falta

La Unidad 1 controló el acceso a la red; aún falta proteger el contenido que viaja por ella.

controles construidos en la Unidad 1 vs. lo que agrega la Unidad 2



Firewall

¿pasa o no pasa?



Segmentación

¿hasta dónde llega?



IDS / IPS

¿parece anómalo?

CIFRADO EN TRÁNSITO

¿qué ve quien intercepta el tráfico?
contenido ilegible aunque la conexión pase

el control de acceso decide si el paquete pasa; el cifrado decide quién entiende lo que pasa

las dos capas son complementarias — no se sustituyen

Qué expone un canal sin cifrar

Escucha pasiva y ataque activo: dos modelos distintos que exigen la misma respuesta.

Escucha pasiva (sniffing)

- copia el tráfico sin modificarlo
- difícil de detectar: nada se altera
- objetivo: credenciales, tokens, contenido
- ejemplo: capturar en una red compartida sin cifrar

Interceptación activa (MITM)

- se coloca entre las dos partes
- puede leer, modificar e inyectar mensajes
- puede dejar rastros de su presencia
- ejemplo: redirección de tráfico hacia un destino falso

Causa común: el protocolo no autentica a los extremos ni garantiza la integridad de lo recibido — el cifrado en tránsito ataca exactamente esas dos carencias.

Las tres garantías que ofrece TLS

Confidencialidad, integridad y autenticación del servidor — definidas así en el estándar.



Confidencialidad

solo los extremos leen el contenido



Integridad

toda alteración se detecta



Autenticación

el servidor siempre; el cliente es opcional

estas garantías se sostienen incluso si el atacante controla toda la red

la autenticación del usuario es otra capa: contraseña, MFA o identidad (semana 7)

Simétrico y asimétrico: por qué TLS usa los dos

El cifrado rápido protege los datos; el cifrado lento resuelve el reparto de la clave.

Cifrado simétrico

- una sola clave para cifrar y descifrar
- muy rápido: protege el volumen de datos
- problema: cómo repartir la clave sin exponerla

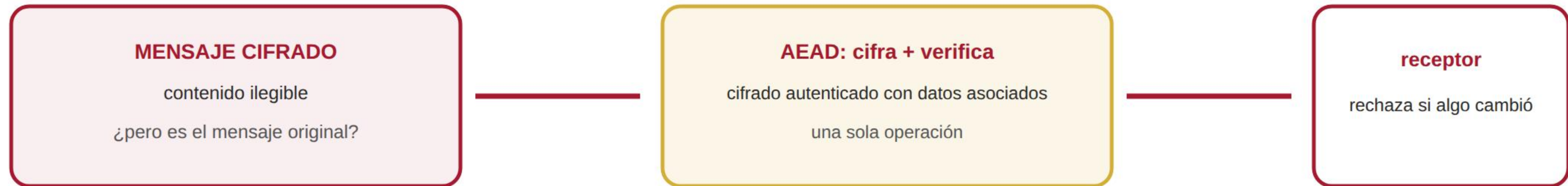
Cifrado asimétrico

- par de claves: pública y privada
- más lento: no cifra el contenido completo
- resuelve la autenticación y el acuerdo de clave

Estrategia de TLS: asimétrico al inicio (autenticar y acordar la clave por Diffie-Hellman) + simétrico para todo el tráfico — la clave compartida nunca viaja por la red.

Cifrar no basta: integridad y AEAD

Un mensaje cifrado puede ser alterado. El receptor necesita poder detectarlo.

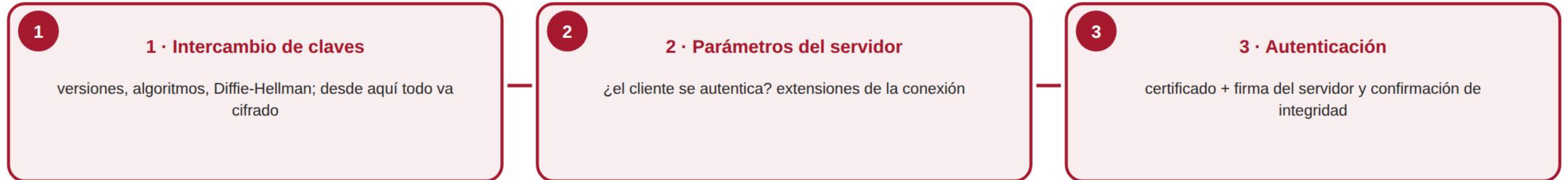


TLS 1.3 solo admite algoritmos AEAD: la integridad no es opcional

confidencialidad e integridad son propiedades distintas — se necesitan las dos

El handshake TLS en tres fases

Acordar parámetros, autenticar al servidor y derivar la clave — sin diagramar bytes.



Diagnóstico en tres fases: parámetros incompatibles → falla en la fase 1; certificado inválido → falla en la fase 3 (autenticación); integridad rota → falla la confirmación final.

TLS 1.3: qué cambió y por qué importa

Elimina el intercambio de clave estático, obliga la confidencialidad hacia adelante y cifra más del handshake.



Confidencialidad hacia adelante

se elimina el RSA estático: aunque la clave privada se filtre después, el tráfico pasado no se descifra



Más handshake cifrado

todo lo que sigue al primer mensaje del servidor viaja cifrado, incluido el certificado



Solo criptografía moderna

se retiran algoritmos heredados; la configuración debe preferir la versión actual

Operación: permitir versiones antiguas solo con razón de compatibilidad documentada — negociar una versión obsoleta desperdicia la protección disponible.

Dónde vive TLS en la red

Entre el transporte y la aplicación: HTTP sobre TLS es HTTPS, pero TLS protege muchos otros protocolos.

Aplicación — HTTP, correo, bases de datos, mensajería, APIs

TLS — canal seguro: confidencialidad, integridad, autenticación

Transporte — TCP: flujo confiable y ordenado

Red — IP: direccionamiento y enrutamiento

HTTPS = HTTP sobre TLS (puerto 443) · TLS no oculta los metadatos de enrutamiento

mTLS: cuando el cliente también se autentica

Certificado en ambos extremos — la base criptográfica de las arquitecturas Zero Trust.

TLS estándar

- el servidor presenta su certificado
- el cliente no se autentica con certificado
- el usuario se autentica aparte (contraseña, MFA)
- caso típico: navegador contra un sitio público

TLS mutuo (mTLS)

- ambos extremos presentan certificado
- cada parte verifica la cadena del otro
- la identidad depende de una clave privada, no de un secreto reutilizable
- caso típico: servicio a servicio, dispositivo a red

Conexión con Zero Trust: verificar criptográficamente a cada extremo en cada conexión reduce el valor de la ubicación en la red como criterio de confianza.

Cuando el cifrado se ataca por los lados

Degradación de versión, eliminación del cifrado y confianza en una autoridad comprometida.



Degradación de versión

forzar la negociación a algo más débil.
Defensa: fijar un mínimo de versión y algoritmos aceptables



Eliminación del cifrado

interponerse y llevar al usuario a una conexión sin cifrar. Defensa: forzar el cifrado en el servidor



Autoridad comprometida

una CA de confianza bajo control del atacante emite certificados válidos. Defensa: controlar en qué autoridades confía el dispositivo

Patrón común: casi nunca se rompe el algoritmo — se rompen los supuestos de configuración o de confianza alrededor de él.

Lo que TLS no protege

Metadatos, extremos comprometidos y datos legibles antes de llegar al canal seguro.



Metadatos visibles

quién habla con quién, dirección de destino, volumen y tiempos del tráfico siguen siendo observables



Extremos no protegidos

si el servidor o el dispositivo están comprometidos, los datos se exponen donde se descifran



Datos fuera del canal

lo que se escribe en un registro local o se envía sin cifrar antes de la conexión segura no está protegido



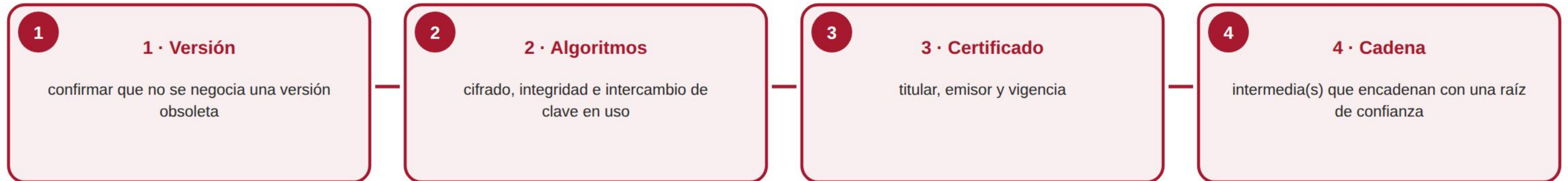
Certificado ≠ honestidad

un certificado válido garantiza el control del dominio, no la buena intención del negocio

Conclusión: el cifrado en tránsito es una capa indispensable, no la única — opera junto a segmentación, identidad y monitoreo.

Verificar un canal: cómo se comprueba

Versión negociada, cifrado, certificado y cadena — cuatro cosas que se inspeccionan en una auditoría.



Hallazgo típico: el problema casi nunca es el algoritmo — es la versión habilitada, los algoritmos ofrecidos o una cadena de certificados incompleta.

Lo que queda de la Parte 1

Tres garantías, un handshake de tres fases y un principio: el canal también es superficie de ataque.

3

garantías de TLS: confidencialidad,
integridad, autenticación del servidor

3

fases del handshake: intercambio de
claves, parámetros, autenticación

2

tipos de ataque al canal: escucha
pasiva y interceptación activa

0

bytes que hay que memorizar: se
entiende el propósito, no el protocolo
byte a byte

Siguiente pregunta: ¿cómo sabe el cliente que la clave pública que recibe pertenece de verdad al servidor y no a un atacante en el medio?



SEMANA 7 · CIFRADO EN TRÁNSITO: TLS/SSL, VPN/IPSEC

PKI y certificados

Parte 2 de 4 · Unidad 2

Ing. Rodolfo Cañas Cervantes

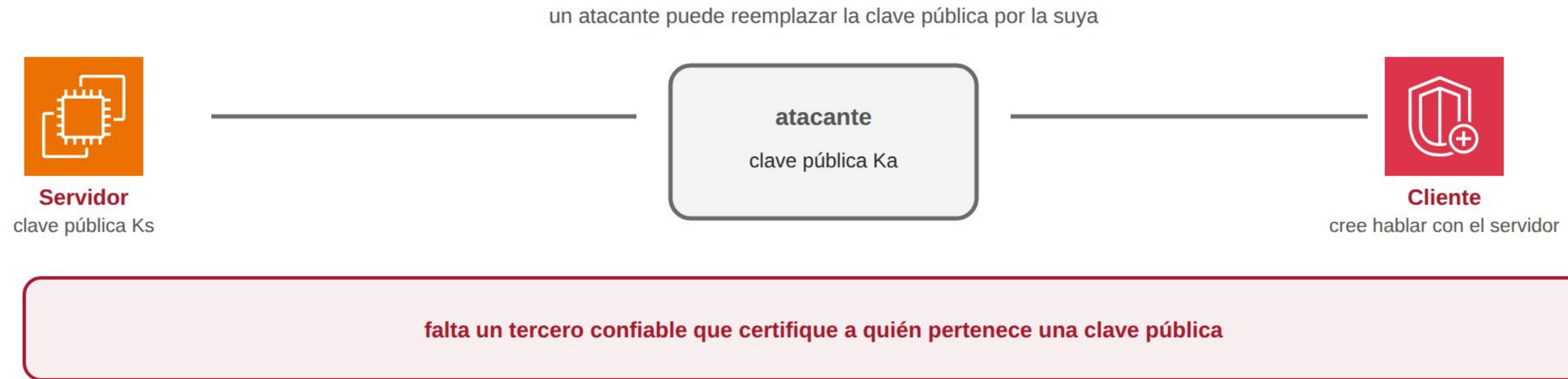
Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

PKI y certificados: cómo se establece la confianza

¿De quién es esa clave pública?

El intercambio de claves no resuelve la identidad: alguien podría poner su propia clave en el medio.



La autoridad certificadora

Firma con su clave privada la afirmación «esta clave pública pertenece a este servidor».



Autoridad certificadora
clave pública preinstalada

firma con su clave privada

CERTIFICADO

clave pública del servidor + nombre + vigencia + firma de la CA

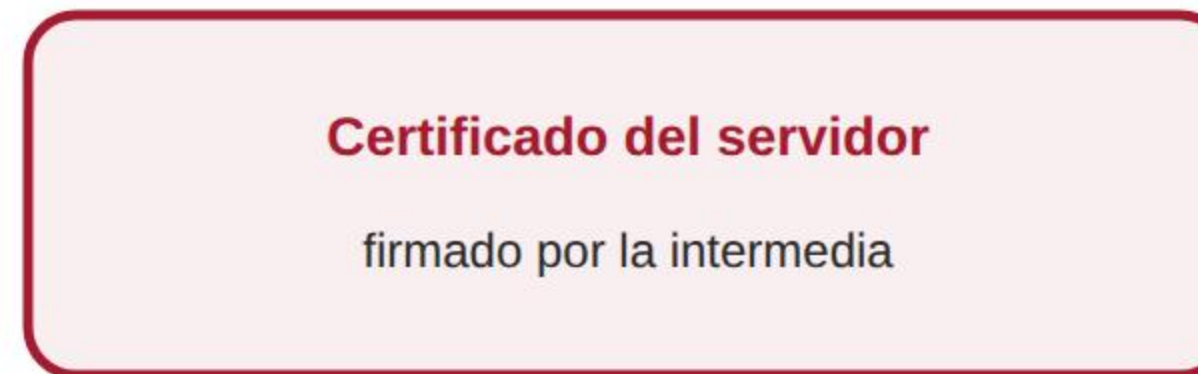
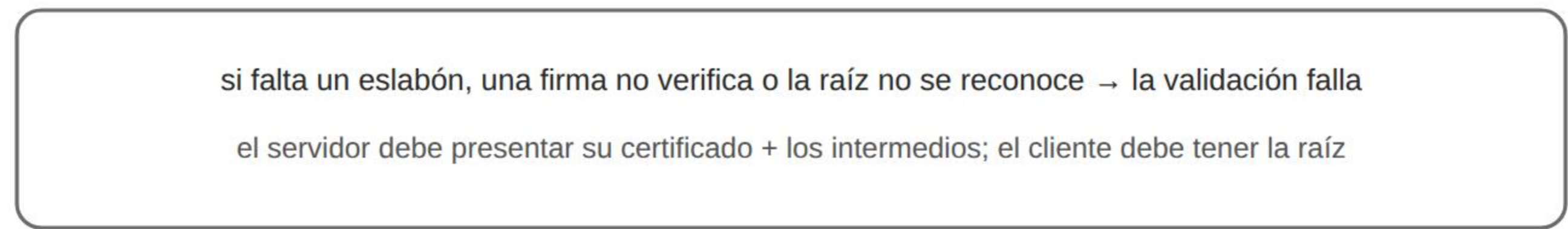
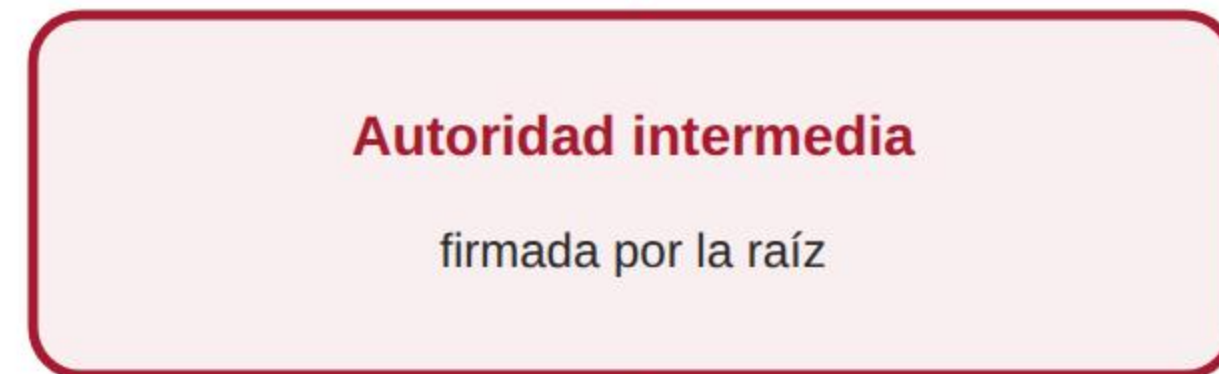
cualquiera que confíe en la CA puede verificar la firma

garantiza identidad técnica del dominio — NO garantiza la honestidad del sitio

el candado dice «conexión cifrada y certificado válido», no «sitio confiable»

La cadena de confianza

Raíz en el dispositivo → autoridad intermedia → certificado del servidor.



Anatomía de un certificado X.509

Los campos que el cliente inspecciona para decidir si acepta la identidad.



Sujeto y emisor

a quién identifica y qué autoridad lo firmó; el emisor debe encadenar con una raíz de confianza



Vigencia

fechas de inicio y fin: fuera de rango se rechaza aunque la firma sea correcta



Clave pública

la clave del titular que se usa para verificar su firma o acordar la sesión



Nombres alternativos (SAN)

para qué dominios es válido; aquí se comprueba el nombre al que me conecto



Uso de la clave

restringe el propósito: firmar, cifrar o autenticación de servidor



Firma de la CA

sella el contenido; si algo cambió, la verificación falla

Validación = firma + vigencia + nombre + uso de clave. Un certificado válido criptográficamente puede ser rechazado por un campo que no corresponde a la conexión.

Qué revisa el cliente, en orden

Cuatro comprobaciones antes de aceptar la identidad de un servidor.



Punto débil: la consulta de revocación puede no responderse y muchos clientes continúan — la vigencia corta y la rotación compensan esa debilidad.

Por qué un autofirmado genera advertencia

El certificado existe y cifra, pero nadie independiente respalda que esa clave sea del servidor.

Certificado firmado por una CA

- la CA valida el control del dominio
- el cliente verifica la cadena hasta una raíz de confianza
- la identidad del servidor queda respaldada por un tercero
- uso correcto: servicios públicos y usuarios desconocidos

Certificado autofirmado

- el servidor firma con su propia clave
- cifra el canal, pero no prueba identidad
- el cliente no tiene forma de distinguirlo de un impostor
- uso correcto: entorno interno con CA propia instalada

Nunca pedir a los usuarios que ignoren la advertencia en un servicio público: eso entrena a aceptar la situación que el certificado debía prevenir.

Comodines y nombres alternativos

Cubrir varios dominios con un certificado: comodidad operativa con un límite de seguridad.

COMODÍN (*.ejemplo.com)

cubre todos los subdominios de un nivel

un solo certificado, una sola renovación

riesgo: si la clave privada se filtra,
el atacante suplanta cualquier subdominio cubierto

CERTIFICADOS ESPECÍFICOS

un certificado por nombre o servicio

más trabajo de emisión y renovación

alcance reducido: un compromiso no expone
al resto de los servicios

menos certificados = menos trabajo; más alcance por certificado = más daño si se compromete

Revocación: invalidar antes del vencimiento

Listas de revocación y consulta en línea — dos mecanismos con un problema operativo común.

Listas de revocación (CRL)

- archivos periódicos con los certificados invalidados
- el cliente descarga la lista y comprueba
- desactualización entre publicaciones: ventana de riesgo

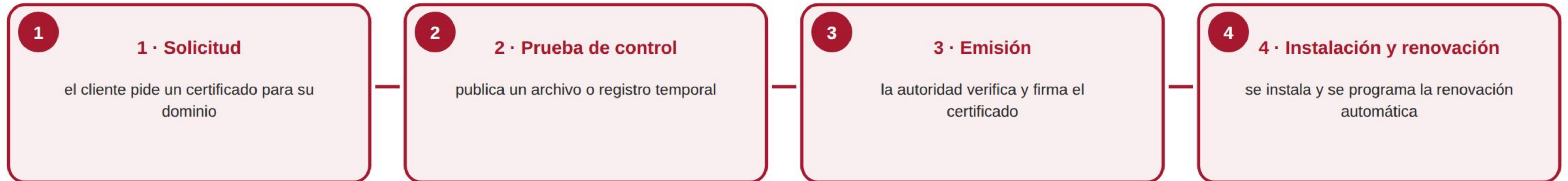
Consulta en línea (OCSP)

- pregunta por un certificado concreto y recibe respuesta firmada
- más inmediata, pero añade latencia
- si el servicio no responde, muchos clientes continúan

Tendencia: certificados de vida corta con renovación automática reducen la ventana de riesgo — menos dependencia de la revocación.

ACME: certificados sin intervención manual

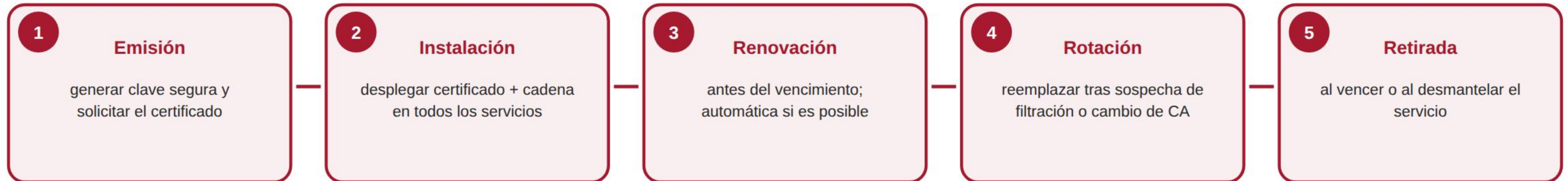
Un protocolo que automatiza la validación del dominio, la emisión y la renovación.



Consecuencia: la vigencia se puede acortar sin más trabajo humano — un certificado gestionado a mano es la excepción justificada, no la norma.

Ciclo de vida de un certificado

Emitir es solo el inicio: renovar, rotar y retirar con proceso definido.



Lo que hace funcionar el ciclo es el inventario: cuántos certificados hay, dónde están desplegados y cuándo vencen — el servicio caído por vencimiento es un fallo de gestión, no técnico.

Quién debe poder verificar el certificado define qué autoridad lo emite.

PKI pública

- raíces preinstaladas en todos los dispositivos
- para servicios expuestos a internet y usuarios desconocidos
- la organización no administra la autoridad

PKI interna (CA privada)

- raíces instaladas explícitamente en equipos y servicios propios
- para autenticación servicio a servicio, mTLS e identidades de dispositivo
- más control, sin depender de una autoridad externa

Criterio de decisión: ¿quién debe poder verificar el certificado? ¿Un sistema externo (pública) o solo sistemas internos (privada)?

Los cinco fallos de certificado más comunes

Ninguno es un fallo criptográfico: todos son de configuración o de proceso.



Vencido

el servicio rechaza la conexión; el usuario ve error de seguridad



Cadena incompleta

falta el intermedio y el cliente no puede llegar a la raíz



Nombre no coincide

el certificado no cubre el dominio por el que se accede



Versión/algoritmos obsoletos

la conexión falla o negocia una protección débil



Autofirmado expuesto

obliga a los usuarios a aceptar advertencias

Solución de proceso: monitoreo de vencimientos + verificación de la cadena + automatización — ninguno de los cinco es un fallo criptográfico.

Lo que queda de la Parte 2

La confianza no es un dato del protocolo: es una cadena de firmas que hay que saber verificar.

4

comprobaciones de validación: cadena,
vigencia, nombre y revocación

6

campos clave de un X.509: sujeto,
emisor, vigencia, clave, SAN, uso

2

modelos de PKI: pública (terceros) e
interna (CA propia)

0

certificados debería emitir una
autoridad pública para un servicio
interno

Siguiente pregunta: ¿cómo se protege el tráfico entre dos redes completas —dos sedes, o una sede y la nube— y no solo entre un servidor y su cliente?



SEMANA 7 · CIFRADO EN TRÁNSITO: TLS/SSL, VPN/IPSEC

VPN e IPsec

Parte 3 de 4 · Unidad 2

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

VPN e IPsec: túneles cifrados para la red híbrida

Qué es una VPN: un túnel sobre red ajena

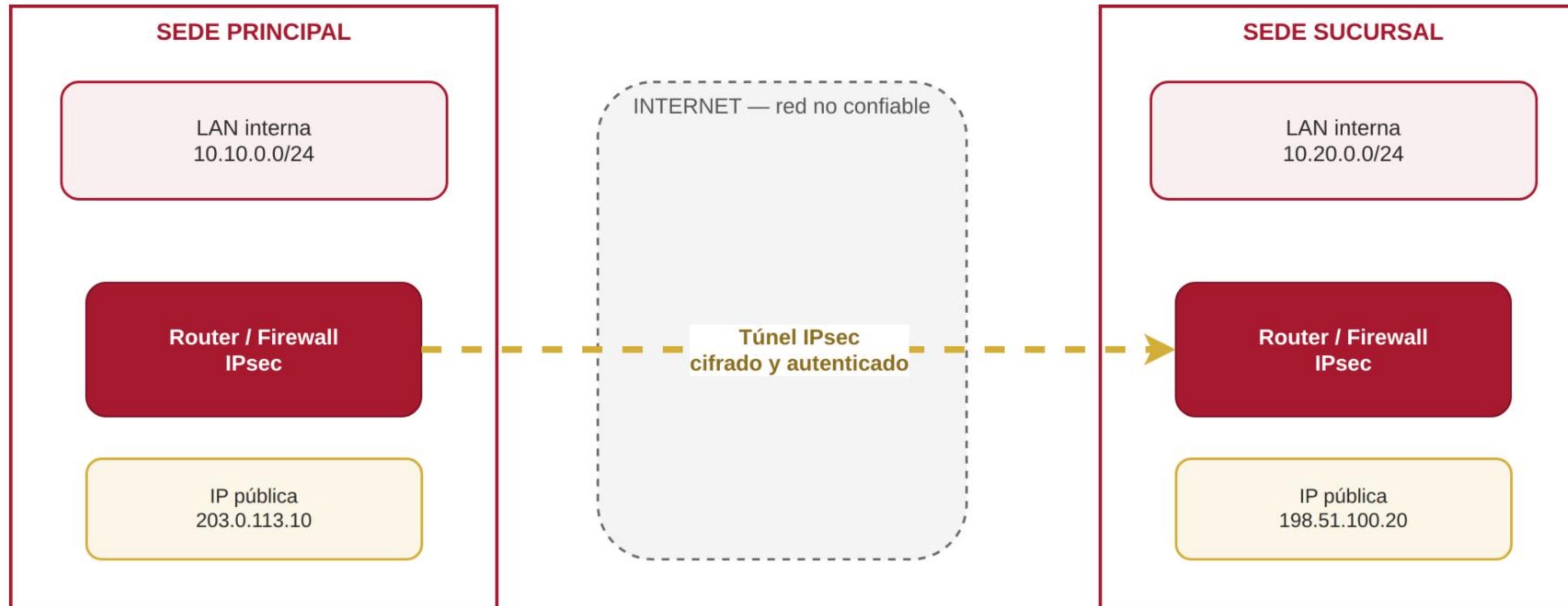
Cifrar y autenticar el tránsito entre dos extremos a través de una red que no se controla.



hacia afuera se comporta como un enlace privado; hacia adentro el tráfico va en claro

VPN de sitio a sitio: unir dos redes

Conexión permanente entre dos redes completas — la sede principal y una sucursal.

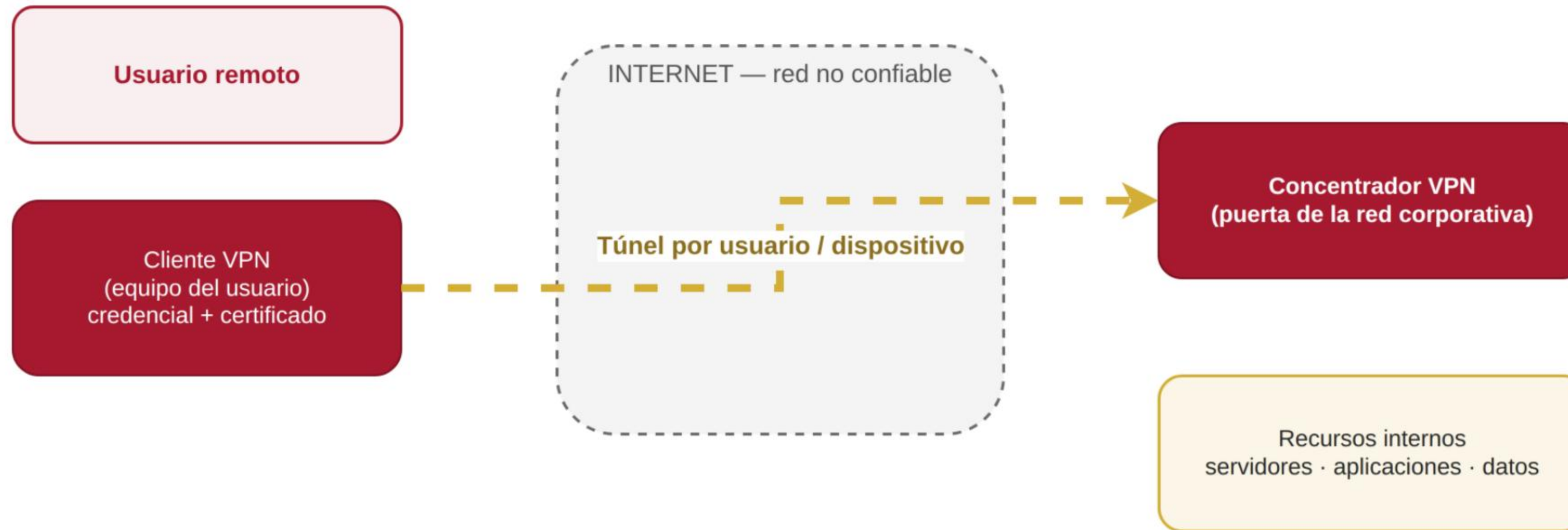


El tráfico entre las dos LAN viaja cifrado: quien intercepte el enlace ve solo el túnel, no el contenido.

Puntos clave: el túnel une las puertas, no los equipos · los hosts internos no configuran nada · internet solo ve tráfico cifrado.

VPN de acceso remoto: unir un usuario a la red

Cada dispositivo abre su propio túnel hacia la red corporativa — teletrabajo y movilidad.



Cada usuario abre su propio túnel cifrado hacia la red corporativa.

Cambio de modelo: relación por usuario/dispositivo con muchos extremos — exige autenticar a la persona y evaluar el estado del equipo, no solo confiar en la puerta.

Sitio a sitio contra acceso remoto

Mismo túnel, distinta relación de confianza y distinto modelo de autenticación.

Sitio a sitio

- conecta dos redes completas
- dos extremos fijos y permanentes
- autentica las puertas entre sí
- configuración de infraestructura

Acceso remoto

- conecta un usuario o dispositivo a la red
- muchos extremos, aparecen y desaparecen
- autentica a cada usuario e integra identidad/MFA
- servicio de identidad y cumplimiento de dispositivo

Error común: gestionar el acceso remoto con la lógica de confianza de una puerta fija — es exactamente lo que Zero Trust cuestiona.

IPsec: dos modos de proteger el tráfico

Modo transporte protege el payload entre dos hosts; modo túnel protege el paquete completo entre dos puertas.

Modo transporte

- protege el payload entre dos hosts
- conserva la cabecera IP original
- uso: dos equipos que se comunican directamente

Modo túnel

- envuelve el paquete completo en uno nuevo
- nuevas direcciones: la red intermedia no ve la topología interna
- uso: entre puertas de red — base de la VPN sitio a sitio

En VPN entre sedes o hacia la nube se usa modo túnel: los paquetes internos viajan envueltos y la red intermedia solo ve las direcciones públicas de las dos puertas.

Fase 1: negociar y autenticar el túnel

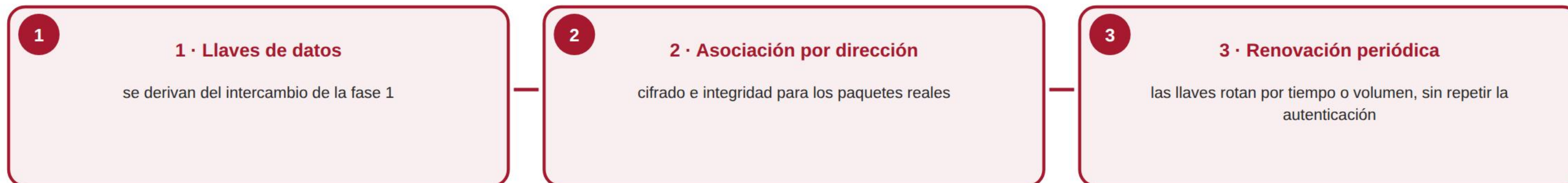
Antes de cifrar datos hay que acordar los parámetros y comprobar que las dos puertas son quienes dicen ser.



Diagnóstico: la mayoría de los problemas de VPN se ven en la fase 1 — parámetros que no coinciden, claves/certificados incorrectos o identidades mal configuradas.

Fase 2: proteger los datos

Con el túnel autenticado, se negocian las llaves y los algoritmos que cifran el tráfico real.



Diagnóstico: un túnel que levanta pero no pasa tráfico suele fallar en la fase 2 — parámetros de datos distintos, redes no incluidas en el enrutamiento o políticas que bloquean el tráfico protegido.

IPsec o VPN sobre TLS

Dos familias de túnel con distinta madurez, compatibilidad y facilidad de configuración.

IPsec

- opera a nivel de red
- estándar para conectar sitios completos
- maduro y eficiente entre redes
- más complejo de configurar entre fabricantes distintos

VPN sobre TLS

- construye el túnel sobre el mismo protocolo del navegador
- atraviesa más fácilmente firewalls y proxys restrictivos
- ideal para acceso remoto, incluso sin instalar cliente
- más simple de desplegar para usuarios

Patrón común: IPsec para sitio a sitio, TLS para acceso remoto — coexisten sin ser inconsistentes, resuelven problemas distintos.

Túnel dividido: todo o solo lo corporativo

Enviar todo el tráfico por el túnel es más seguro; enviar solo el corporativo es más eficiente y también más riesgoso.

Túnel completo

- todo el tráfico pasa por la red corporativa
- queda sujeto a los controles de la organización
- consume los enlaces de la empresa con tráfico no laboral

Túnel dividido

- solo el tráfico corporativo entra al túnel
- más eficiente para la red y para el usuario
- puente potencial: un equipo infectado puede alcanzar recursos internos

Regla: que sea una decisión consciente y documentada, no un valor por defecto que nadie revisó — en redes críticas, modo completo.

Por qué Zero Trust cuestiona la VPN

«Estás dentro del túnel, entonces confío en ti» deja de ser un criterio válido.

Modelo VPN clásico

- confianza por ubicación: dentro del túnel = dentro de la red
- acceso amplio a los recursos internos
- la autenticación ocurre una vez al conectar
- se asume que el dispositivo y el usuario son confiables

Enfoque Zero Trust

- cada acceso se verifica por identidad, dispositivo y contexto
- acceso específico a la aplicación solicitada, no a toda la red
- verificación continua, no solo al conectar
- la VPN pasa a ser transporte, no frontera de confianza

No desaparecen: las VPN de sitio a sitio siguen siendo necesarias para infraestructura — cambia el acceso de usuarios, no el transporte entre redes.

VPN entre la red corporativa y la nube

El mismo túnel de sitio a sitio, con una puerta en la red propia y otra administrada en la nube.



Túnel entre sitios

conecta la red corporativa con la red virtual del proveedor mediante IPsec — mismo concepto de esta clase



Acceso remoto administrado

conecta usuarios con la red virtual sin administrar el concentrador; integra identidad



Red virtual

el extremo del túnel en la nube: subredes, rutas y reglas — lo construido en la semana 4

Distinción de la semana: este túnel es cifrado **en tránsito**; el laboratorio de la semana es KMS, cifrado **en reposo**. Contrapartes, no el mismo tema.

Operar un túnel: lo que rompe en producción

MTU, fragmentación, redundancia y monitoreo — los detalles que hacen la diferencia entre un túnel que existe y uno que sirve.



Tamaño de paquete (MTU)

las cabeceras del túnel reducen el tamaño útil: sin ajuste, falla en transferencias grandes



Redundancia

dos túneles sobre rutas o proveedores distintos con conmutación automática; un túnel solo es punto único de fallo



Monitoreo

que esté arriba, cuánta latencia agrega y si renueva llaves — no solo que exista



Parámetros documentados

la causa más común entre fabricantes distintos: algoritmos o identificadores que nadie documentó

Regla operativa: un túnel es un enlace crítico — redundante, monitoreado y con parámetros conocidos por ambos lados.

Lo que queda de la Parte 3

VPN como túnel cifrado, dos tipos, dos fases de IPsec y un cambio de modelo hacia Zero Trust.

2

tipos de VPN: sitio a sitio y acceso remoto

2

modos de IPsec: transporte y túnel

2

fases de IPsec:
negociación/authenticación y protección
de datos

ZT

la identidad reemplaza a la ubicación
como criterio de confianza

Puente a la Parte 4: todo lo visto hoy cifra el tránsito; el laboratorio de la semana cifra el reposo — hay que distinguirlos con precisión.



SEMANA 7 · CIFRADO EN TRÁNSITO: TLS/SSL, VPN/IPSEC

Tránsito, reposo y laboratorio

Parte 4 de 4 · Unidad 2

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 7 · Periodo 2026-2 · Barranquilla, Colombia

Del tránsito al reposo: KMS y el laboratorio de la semana

Tránsito y reposo: dos problemas distintos

El dato se mueve o el dato se guarda — el adversario, el punto de fallo y la herramienta cambian.

CIFRADO EN TRÁNSITO

el dato se mueve

adversario: quien intercepta el canal

punto de fallo: el enlace

herramientas: TLS · IPsec

CIFRADO EN REPOSO

el dato se guarda

adversario: quien obtiene el soporte o la copia

punto de fallo: la llave que lo protege

herramientas: gestión de llaves · KMS

un sistema maduro aplica las dos al mismo dato — no se sustituyen, se complementan

Qué protege el cifrado en reposo

Discos, objetos, copias y bases de datos: el dato dormido también es un objetivo.



Discos

volúmenes de las máquinas: si el soporte físico se pierde o se filtra, el contenido no se lee



Objetos y archivos

contenido almacenado en el servicio de objetos y en sistemas de archivos



Copias de seguridad

una instantánea filtrada expone los datos si no estaba cifrada



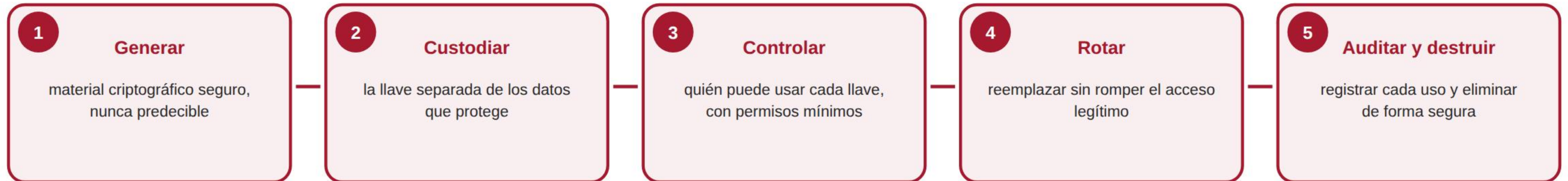
Bases de datos

datos y registros de las bases, cifrados en el motor o en el volumen

Límite: no protege contra una cuenta comprometida con permisos para descifrar — protege contra la pérdida del soporte y el acceso indebido al medio.

Gestionar llaves es el verdadero reto

El algoritmo está resuelto; lo difícil es generar, custodiar, rotar y retirar llaves sin exponerlas.



Punto crítico: guardar la llave junto a los datos anula el cifrado; perder la llave equivale a perder el dato — no se recupera como una contraseña.

KMS: gestión de llaves administrada

Un servicio que crea, custodia y audita llaves sin exponer el material criptográfico.



Custodia el material

las operaciones de cifrado se piden al servicio; la llave nunca se entrega expuesta



Controla el uso

políticas que definen qué identidades y servicios pueden usar cada llave



Audita cada uso

registro de quién usó cada llave y cuándo; trazabilidad para investigar



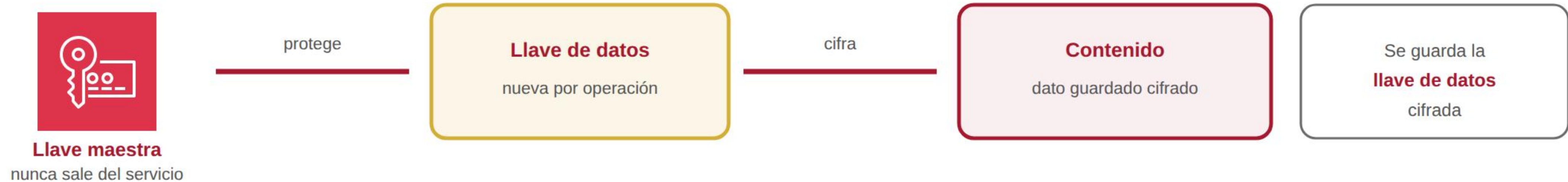
Rota sin romper

nuevo material sin perder el acceso a lo cifrado anteriormente

Decisión de equilibrio: llaves propias administradas (control, permisos, auditoría) vs. llaves del proveedor (simplicidad) — el laboratorio usa las propias administradas.

Cifrado con sobre: llave de datos y llave maestra

No se cifra cada archivo con la llave principal: se genera una llave de datos por operación y se protege con la principal.



rotar la llave maestra no obliga a recifrar el contenido: solo se recifran las llaves de datos

por eso la rotación es viable a escala

KMS es contraparte, no repetición

Lo que cambia el laboratorio frente a la clase: el momento del dato y el papel de la llave.

Lo que se vio en clase

- cifrado en tránsito: el dato se mueve
- TLS entre cliente y servidor
- certificados e infraestructura de clave pública
- IPsec para túneles entre redes
- adversario: quien intercepta el canal

Lo que trabaja el laboratorio

- cifrado en reposo: el dato se guarda
- gestión de llaves con un servicio administrado
- custodia, control de uso, rotación y auditoría
- cifrado con sobre: llave de datos + llave maestra
- adversario: quien obtiene el soporte o la copia

No es el mismo tema dos veces: son dos momentos del ciclo de vida del dato — un sistema completo aplica las dos protecciones.

Actividad calificada del 10 % de la Unidad 2 — gestión de llaves para cifrado en reposo.

Lab 5.1 AWS Academy · 10 % (Unidad 2)

Gestión de llaves con el servicio administrado, aplicada al cifrado **en reposo**. Se evalúa de forma automática revisando los recursos reales creados en la cuenta del estudiante.



Crear la llave

llave administrada por la organización, con su política



Definir el uso

qué identidades y servicios pueden usar la llave



Proteger un dato

cifrado en reposo con la llave creada



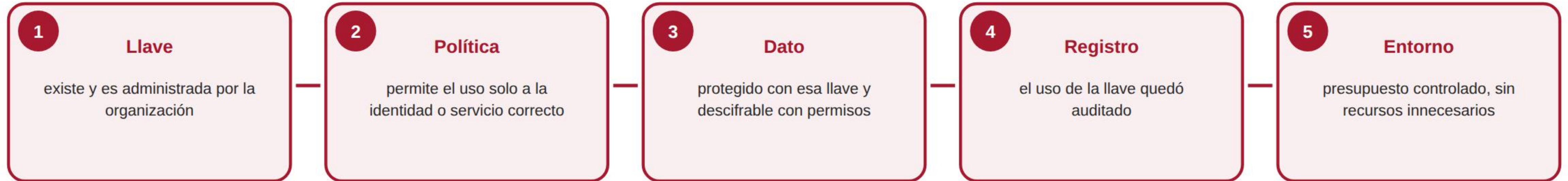
Verificar el registro

comprobar que el uso de la llave quedó auditado

No es el tema de la clase: aquí se cifra el reposo — la contraparte del TLS/IPsec de las Partes 1 a 3.

Checklist antes de enviar el laboratorio

Cinco verificaciones que evitan perder el 10 % por un detalle de política o de registro.



Propio de KMS: la rotación es una configuración, no una acción destructiva — actívenla solo si el enunciado lo pide.

Cifrado en la nube: las dos mitades juntas

TLS en los extremos, VPN entre sitios y gestión de llaves para el reposo — el cuadro completo.

el mismo dato, protegido en los dos momentos de su ciclo de vida

EN TRÁNSITO



TLS en extremos



VPN entre sitios

certificados · túneles · mTLS interno

EN REPOSO



Discos y objetos



Bases y copias

llaves administradas · políticas · auditoría

ninguna mitad sustituye a la otra — el sistema completo aplica las dos

El cifrado como requisito, no como opción

La protección de datos personales y los marcos de seguridad convierten el cifrado en una obligación.



Normativa de datos personales

exige medidas de seguridad; en Colombia, la Ley 1581 de 2012 establece el marco de protección



Marcos de seguridad

estándares adoptados por la organización o exigidos por contrato incluyen cifrado y gestión de llaves



Evidencia

hay que poder demostrar cómo se gestionan las llaves, quién accede y cómo se audita

Consecuencia: un cifrado por defecto sin control de llaves puede no ser suficiente para un cumplimiento serio — protege el soporte, no responde a la gobernanza.

Los cinco errores clásicos de cifrado

Ninguno es un fallo del algoritmo: todos son de gestión, configuración o proceso.



Llave junto al dato

si el cifrado y la llave viven en el mismo lugar, la protección se pierde con el archivo



Sin rotación

o sin una forma de rotar que no rompa el acceso al dato existente



Versiones obsoletas en tránsito

configuraciones antiguas que negocian protección débil



Cifrado sin gobernanza

llaves por defecto sin control de quién puede descifrar ni auditoría propia



Pérdida de la llave

irrecuperable: no se restablece como una contraseña

Solución de proceso: servicio de gestión de llaves + documentar qué llave protege qué dato + automatizar la rotación + verificar el descifrado legítimo.

Semana 7 en cuatro ideas

Tránsito, identidad del canal, túneles y reposo: el mapa completo del cifrado.

TLS

canal seguro: confidencialidad,
integridad y autenticación del servidor

PKI

la confianza se apoya en cadenas de
certificados verificadas

VPN

extiende el cifrado a redes y usuarios;
IPsec en 2 fases y 2 modos

KMS

contraparte en reposo: gestión de
llaves, control y auditoría

Laboratorio S6 · 10 %: gestión de llaves (KMS, cifrado en reposo) — **Próxima semana S7:** identidad y acceso en red, Zero Trust a fondo (ejercicio propio de control de acceso).

De vuelta al curso: qué sigue

El cifrado asegura el canal y el dato; la semana siguiente asegura el acceso.

dónde estamos en el curso

UNIDAD 1

red y puntos de control

firewalls · segmentación · IDS

¿quiénes entran?

ESTA SEMANA

cifrado en tránsito

TLS · PKI · VPN/IPsec

+ laboratorio KMS (reposo)

SEMANA 7

identidad y acceso

MFA · mínimo privilegio · Zero Trust

¿qué puede hacer cada quien?

un canal cifrado con un usuario mal autenticado sigue siendo un canal inseguro